- **Objective and scope**
    - This assessment uses NIST CSF 2.0 to compare a fictional small business's security practices with selected cybersecurity outcomes. It identifies gaps, explains their risks, and prioritizes improvements. All business details and evidence are simulated; this is a learning exercise, not a real audit or certification.
- **Fictional business overview**
    - Garden State Sports is a fictional sports training business with 20 employees. It uses company laptops, cloud email, and an online booking and payment platform. It stores athlete contact information, training schedules, and employee records. One IT administrator manages its systems. This assessment covers company devices, cloud services, user access, backups, security monitoring, and incident response.
- **Assessment method**
    - Compare simulated business evidence with selected outcomes across NIST CSF 2.0's six functions: Govern, Identify, Protect, Detect, Respond, and Recover. Rate each selected outcome as Met, Partially met, Not met, or Unknown. Record the evidence, gap, business risk, and recommended improvement. These ratings are defined for this exercise, not official NIST scores. High priority addresses direct exposure or major detection and recovery weaknesses. Medium priority addresses supporting governance and inventory gaps.
- **Current controls and evidence**
    - *Evidence 1:* Simulated management interview: The owner assigns security tasks to the IT administrator, but there is no written security policy or backup person responsible for security decisions.
    - *Evidence 2:* Simulated asset inventory review: Garden State Sports lists 15 of its 20 company laptops. The list does not identify device owners, and there is no inventory of cloud services or the athlete information they store.
    - *Evidence 3:* Simulated access review: Employees have individual cloud accounts, but multifactor authentication (MFA) is enabled only for the IT administrator. Two former employees still have active accounts.
    - *Evidence 4:* Simulated monitoring review: Cloud sign-in logs are available, but nobody regularly reviews them. Alerts for suspicious sign-ins are not configured, and no one is assigned to investigate them.
    - *Evidence 5:* Simulated incident response review: Employees report suspicious activity to the IT administrator, but there is no written response plan, incident log template, or backup contact. No response exercise has been conducted.
    - *Evidence 6*: Simulated recovery review: Client and athlete records are backed up weekly, but no restore test has been completed. The business has no documented recovery procedure or agreed target for restoring booking services.

- **Gaps and risks:**
  - *Gap01:* Security responsibilities and policy (Govern)
    - Evidence 1.
    - Rating*:* Partially met.
    - *Gap*: Security tasks have an owner, but no written policy or backup decision-maker.
    - Business risk: If the IT administrator is unavailable, responding to an incident could be delayed, disrupting athlete bookings and training schedules.
  - *Gap02:* Incomplete asset inventory (Identify)
    - Evidence 2.
    - Rating: Partially met.
    - Gap: Five laptops, device owners, cloud services, and stored athlete information are missing from the inventory.
    - Business risk: Untracked devices or services could be overlooked during security updates or an incident, exposing athlete information and disrupting bookings.
  - *Gap03:* Weak account access controls (Protect)
    - Evidence 3.
    - Rating: Partially met.
    - Gap: Most accounts lack MFA, and two former employees retain active accounts.
    - Business risk: Stolen passwords or former employee access could expose athlete information or allow unauthorized changes to bookings.
  - *Gap04:* Limited security monitoring (Detect)
    - Evidence 4.
    - Rating: Partially met.
    - Gap: Sign-in logs exist, but regular reviews, suspicious sign-in alerts, and investigation responsibilities are missing.
    - Business risk: Unauthorized account access could go unnoticed, giving an attacker more time to access athlete information or change bookings.
  - *Gap05:* Incomplete incident response preparation (Respond)
    - Evidence 5.
    - Rating: Partially met.
    - Gap: Reporting is informal, with no written response plan, incident log template, backup contact, or practice exercise.
    - Business risk: Confusion during an incident could delay containment, lead to lost evidence, and prolong disruption to athlete bookings.
  - *Gap06:* Untested recovery capability (Recover)
    - Evidence 6.

        - Rating: Partially met.
        - Gap: Backups have not been tested, and recovery steps and restoration targets are undocumented.
        - Business risk: Unusable backups could delay recovery. Weekly backups could also leave up to a week of recent records unavailable after data loss.
- **Prioritized improvement plan**
    - *Gap01:* Document security responsibilities
        - Action: Create an owner-approved security policy defining responsibilities and a backup decision-maker.
        - Priority: Medium.
        - Owner: Business owner, supported by the IT administrator.
        - Target: Within 30 days of the simulated assessment.
        - Completion evidence: Approved policy and documented backup assignment.
    - *Gap02:* Complete the asset inventory
        - Action: List all 20 laptops, their owners, cloud services, and the types of athlete information stored.
        - Priority: Medium.
        - Owner: IT administrator.
        - Target: Within 30 days of the simulated assessment.
        - Completion evidence: Updated inventory checked against device and cloud account records.
    - *Gap03:* Strengthen account access
        - Action: Disable former employees' accounts, revoke their sessions, require MFA for all supported accounts, and document an employee departure checklist.
        - Priority: High.
        - Owner: IT administrator, with departure notifications from management.
        - Target: Remove former employee access within 1 day; complete MFA rollout within 14 days of the simulated assessment.
        - Completion evidence: Account review, MFA settings, and approved departure checklist.
    - *Gap04:* Improve security monitoring
        - Action: Configure supported suspicious sign-in alerts, assign a reviewer and backup, and document how to escalate findings.
        - Priority: High.
        - Owner: IT administrator.
        - Target: Within 14 days of the simulated assessment.
        - Completion evidence: Alert settings, assigned responsibilities, and a documented test showing an alert reaches the reviewer.

    - *Gap05:* Prepare and test incident response
        - Action: Create a response plan, incident log template, and primary and backup contact list. Test them through a tabletop exercise.
        - Priority: High.
        - Owner: IT administrator, supported by the business owner.
        - Target: Within 30 days of the simulated assessment.
        - Completion evidence: Approved plan, log template, contact list, and tabletop findings.
    - *Gap06:* Test and document recovery
        - Action: Test restoring backups in a separate environment, document recovery steps, and agree on acceptable downtime and data loss. Adjust backup frequency to meet those targets.
        - Priority: High.
        - Owner: IT administrator, with targets approved by the business owner.
        - Target: Within 14 days of the simulated assessment.
        - Completion evidence: Restore test results, approved recovery targets, and documented recovery procedure.
- **Limitations**
    - This assessment uses fictional evidence and reviews only selected outcomes across the six NIST CSF 2.0 functions. No systems, settings, or backups were tested. Ratings and priorities are judgments for this exercise, not official NIST scores. Proposed improvements have not been implemented or verified.